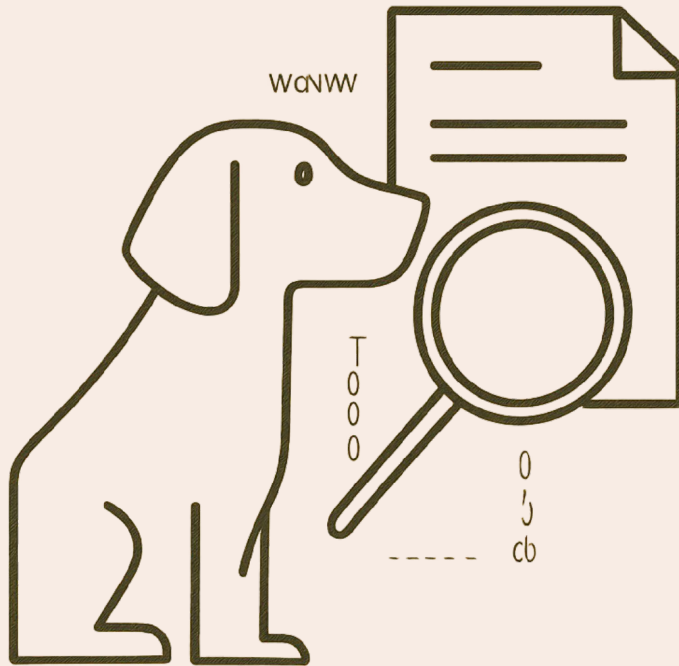




PromptHound

Static Risk Analysis for AI Agent Skill Files

"Detecting Hidden Threats Before AI Agents Execute Them"

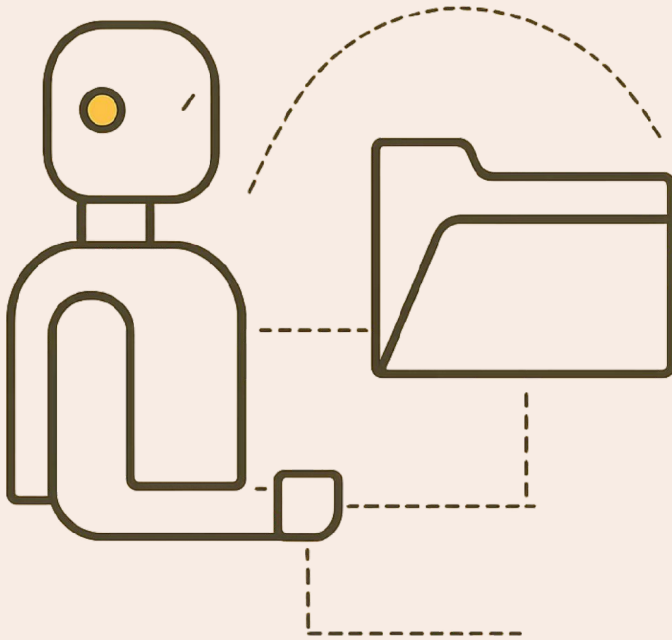
Developed by:

- Barinderpreet Singh
- Mehakdeep Kaur
- Inderpreet Singh
- Tushar Kumar



प्रगत संगणन विकास केंद्र
CENTRE FOR DEVELOPMENT OF ADVANCED COMPUTING

AI agents don't do everything out of the box — they learn new abilities from files.



Base Skillset

AI agents (coding assistants, automation bots) ship with a base skillset.

Skill Files

To extend what they can do, agents load **skill files** – markdown-based capability packages (e.g. SKILL.md) that describe a task, its instructions, and what tools/permissions it needs.

Injected Instructions

Conceptually similar to how a RAG system injects external documents into an LLM's context – except here, the injected content isn't just *information*, it's **instructions the agent may act on**.

Minimal Review

Skills are downloaded from marketplaces, GitHub repos, or shared informally between developers – often installed and run with minimal review.

Whatever an agent can read, an attacker can weaponize.

Because skill files are just text, they can hide:

- Hidden shell/interpreter commands (eval, exec, shell pipelines)
- Base64/hex-encoded malicious payloads
- Hardcoded credential exposure
- Capability mismatches (file says one thing, does another)

This is a **supply-chain attack** – same pattern as malicious npm/PyPI packages, but for agent skills. Marketplace-style attacks on skill registries are already an emerging real-world threat class.

Scenario: A developer pulls a skill from GitHub to automate coding tasks. It contains hidden shell commands and an encoded payload. The agent executes it automatically. Result → data leakage, unauthorized system access, security breach.

Most agent tooling today executes skills with no dedicated offline security check first.

A sniffer, not a shield.

Static Analysis

PromptHound performs **static risk analysis** on skill files *before* an agent ever touches them.

Never Executes

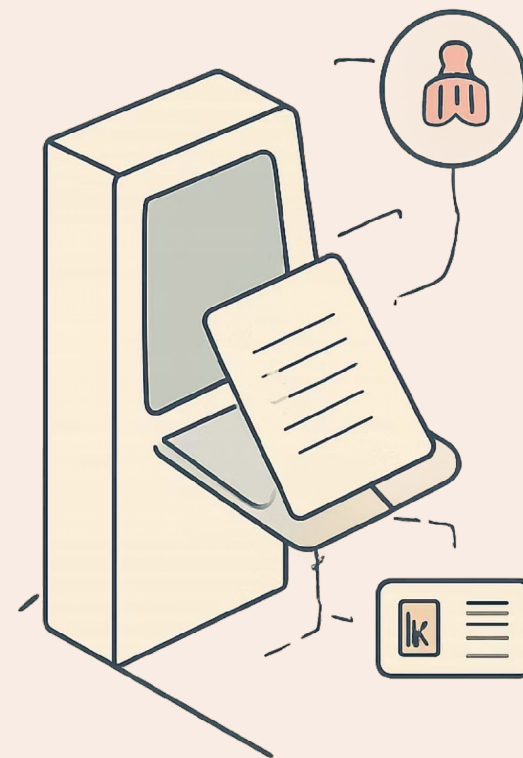
It never executes the file – it only reads and scores it.

Detect, Score, Explain

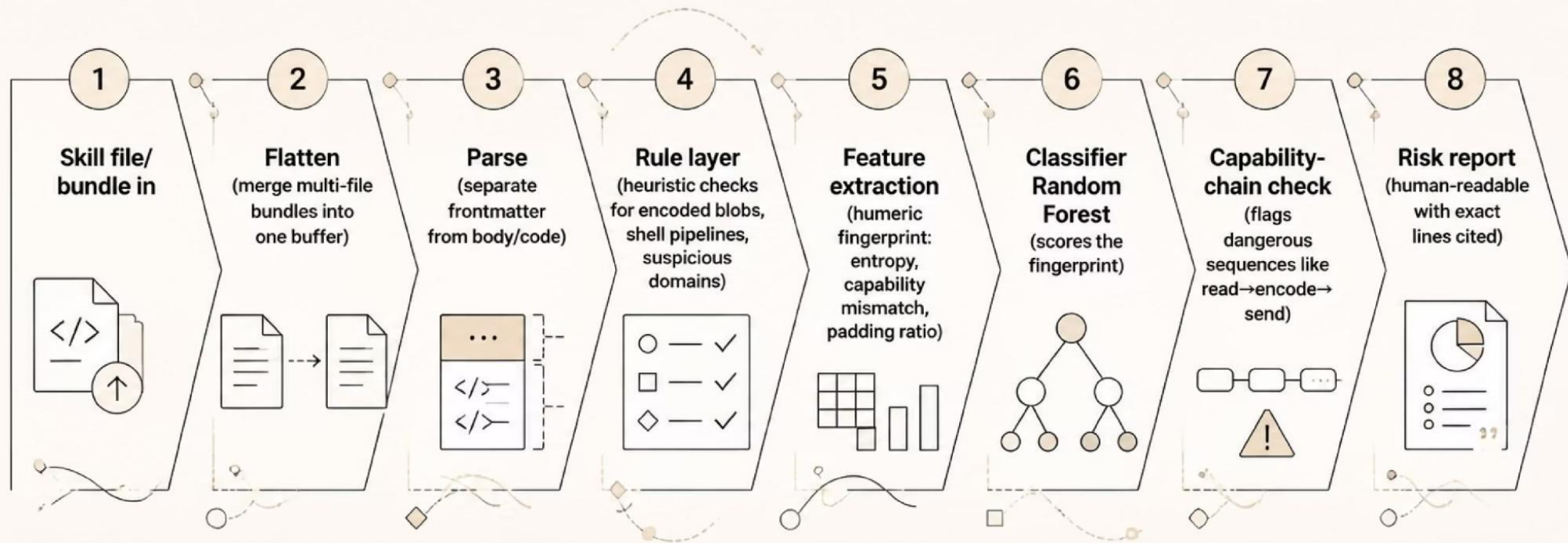
Philosophy: **detect, score, explain** – the tool surfaces risk with reasoning; the final call to block or allow always stays with the developer or CI pipeline. No opaque auto-blocking.

What It Checks

Checks for: dangerous commands, credential exposure, obfuscation, capability mismatch, suspicious patterns.



From raw file to explainable risk score.





Three design decisions that make PromptHound different.



Anti-Dilution Architecture

Attackers can hide a malicious payload by padding it inside a large bundle of benign files, diluting risk signals. PromptHound computes risk ratios **per file member** and takes the max across the bundle, so padding can't bury a threat.



Heuristic Engine

Catches known-bad patterns instantly: dangerous interpreter calls, shell access, base64/hex obfuscation, credential leakage.



Interpretable Random Forest Classifier

Every score comes with a plain-language reason ("this file scored high because X, Y, Z"), traced feature-by-feature through the model – not a black box.

Accurate enough to trust, careful enough not to cry wolf.

Selected model: Random Forest (max_depth=10, n_estimators=50)

0.757

Holdout F1 Score

1.22%

Severe False-Positive Rate

Safe files incorrectly flagged as malicious – this is why PromptHound stays a sniffer, not an auto-blocker: a real but small error rate means final judgment must stay human.

Explainability isn't an afterthought – each prediction is decomposed feature-by-feature so developers see *why*, not just a number.

Built for the gap enterprise tools don't cover.

Tool	Approach	Trade-off
NVIDIA SkillSpector	Sends skills to an LLM for semantic evaluation + OSV.dev lookups	Needs network + LLM calls; not air-gapped
Cisco skill-scanner	YARA rules + LLM-as-judge + dataflow analysis	Heavier, targets specific agent ecosystems
Tencent AI-Infra-Guard	Full red-teaming platform, Docker-based	Enterprise-scale, not lightweight
PromptHound	Offline heuristics + interpretable ML	Zero network calls, sub-second scans, fully auditable Python source

PromptHound targets the gap **between individual developer tooling and enterprise-scale registry auditing** – the everyday pre-commit / pre-install check nobody else offers offline.

No LLM dependency → deterministic, reproducible results across every CI run. No variance, no API cost, no data leaving the machine.

Fits anywhere a skill file gets installed.

Where it fits:

- Software companies & AI dev platforms
- Open-source projects
- Enterprise security / DevSecOps teams
- CI/CD pipelines
- Government & regulated organizations

Why it wins:

- Fully offline, no network dependency
- Fast – sub-second scans
- Low false positives (developers aren't blocked by noise)
- Explainable, not a black box
- Easy to drop into existing CI/CD and git workflows
- Privacy-preserving – skill files never leave the machine

Securing the agent supply chain, one skill file at a time.

PromptHound combines heuristic detection with an interpretable ML classifier to catch malicious skill files **before** they run – offline, fast, and explainable.

Already underway:

- CI integration
- MCP server integration
- PromptHound-as-a-skill distribution

On the horizon:

- Broader agent-framework support
- Enterprise policy management
- Cloud dashboard for fleet-wide visibility

"As AI agents take on more autonomy, the files that extend them need the same scrutiny as the code they run. PromptHound is that first line of defense."

